PROFESSIONAL SECURITY REPORT

Web Application Vulnerability Assessment

JL-WEB-001

Client-Side Price Manipulation

Insufficient Server-Side Validation of Business-Critical Parameters

Prepared by: Jiwosh Shrestha

Course: Web Security & Penetration Testing

Assignment: Day 40 — Professional Security Report

Date: 15 October 2026

Classification: CONFIDENTIAL

This document contains confidential security findings intended solely for the authorized recipient.
Unauthorized distribution or disclosure is prohibited.

1. Confidentiality Notice

This report is classified CONFIDENTIAL. It is intended only for the authorized course instructors and the named student. The findings describe a vulnerability identified in a controlled training laboratory environment. No production systems were tested. Redistribution, publication or use of this material outside the authorized training context is prohibited.

2. Document Information

Document Title: Professional Security Report — JL-WEB-001

Finding ID: JL-WEB-001

Author: Jiwosh Shrestha

Course: Web Security & Penetration Testing

Assessment Date: Day 39–40 Training Lab (October 2026)

Target: PortSwigger Web Security Academy training application

Version: 1.0

Classification: CONFIDENTIAL

3. Executive Summary

During authorized manual testing of a PortSwigger Web Security Academy training application, a critical business-logic vulnerability was identified and validated. The application accepted a client-supplied price parameter at the checkout endpoint without performing server-side re-validation against the authoritative product catalogue. By intercepting the legitimate checkout request with Burp Suite and modifying only the price value, an attacker could complete a purchase at an arbitrary price (demonstrated reduction from $13.37 to $0.01). The vulnerability enables direct financial fraud and undermines the integrity of the e-commerce transaction process. The root cause is the absence of server-side validation of business-critical parameters that originate from the client. Immediate remediation requires calculating and enforcing prices exclusively on the server, discarding any client-supplied price values, and implementing anomaly detection for price deviations. This report documents the finding, provides reproducible evidence, assesses impact, and supplies concrete remediation guidance. No production systems were affected; all testing occurred within the authorized training laboratory.

4. Assessment Scope

In-Scope: The single PortSwigger Web Security Academy lab instance assigned for Day 39 manual testing (host pattern: *.web-security-academy.net). Testing was limited to authenticated and unauthenticated functions visible through the normal user interface, with focus on the shopping-cart and checkout workflow. Out-of-Scope: All production systems, third-party services, denial-of-service testing, social engineering, and any host not belonging to the assigned lab instance.

5. Methodology

Testing followed a manual, hypothesis-driven approach using Burp Suite Professional. After establishing a normal baseline by completing a legitimate purchase, the checkout request was sent to Burp Repeater. A single business-critical parameter (price) was modified while all other values remained constant. The server response and subsequent order confirmation were observed to determine whether the modification was accepted. All session cookies and tokens shown in evidence have been redacted.

6. Limitations

This assessment was performed exclusively against a controlled training laboratory application. Results are not transferable to any production environment. Only one parameter-manipulation scenario was fully validated. Automated scanning was not used. The tester had normal user-level credentials only; administrative interfaces were not assessed.

7. Findings Summary

JL-WEB-001 | Client-Side Price Manipulation | Severity: HIGH

Endpoint: POST /cart/checkout | Parameter: price

Impact: Financial fraud — arbitrary purchase price accepted by server

Status: Validated in training lab (Day 39)

Severity Justification: The vulnerability allows an unauthenticated or low-privilege attacker to cause direct financial loss with minimal effort and high reliability. No special privileges beyond a normal user session are required. Exploitability is trivial (single parameter change in Burp Repeater). Business impact is high because every completed transaction can be manipulated. Therefore the finding is rated HIGH.

8. Detailed Finding — JL-WEB-001

8.1 Affected Function / Endpoint

Function: Shopping-cart checkout

Endpoint: POST /cart/checkout

Method: POST

Parameter: price (application/x-www-form-urlencoded)

8.2 Description

The application includes a client-supplied price parameter in the checkout request. The server accepts the value without re-calculating or validating it against the product catalogue stored on the server. Consequently an attacker can replace the legitimate price with any numeric value and complete the purchase at the attacker-chosen price.

8.3 Root Cause

Absence of server-side validation (or authoritative re-calculation) of a business-critical parameter that is fully controlled by the client. The application trusts data that the normal UI generated, violating the principle that all security decisions must be enforced on the server.

8.4 Steps to Reproduce

1. Log in to the training application with a normal user account and add any product to the cart.
2. Proceed to checkout while Burp Suite proxy is intercepting traffic.
3. Capture the POST /cart/checkout request and send it to Burp Repeater.
4. Observe the baseline price parameter (e.g., price=1337).
5. Modify only the price parameter to a lower value (e.g., price=1).
6. Forward the modified request and observe the server response.
7. Confirm that the order is accepted and the confirmation reflects the modified price.

8.5 Expected vs Actual Behaviour

Expected: Server rejects or ignores client-supplied price; order total is calculated server-side.

Actual: Server accepts the modified price and completes the order at the attacker-chosen value.

8.6 Evidence (Redacted)

Figure 1 — Burp Repeater (modified request / response) [REDACTED]

```
POST /cart/checkout HTTP/1.1
Host: [lab-host].web-security-academy.net
Cookie: session=[REDACTED]
productId=1&price=1&quantity=1
→ HTTP/1.1 200 OK  |  Order confirmed for $0.01
```

8.7 Impact

An attacker can purchase any item at an arbitrary price, resulting in direct financial loss to the merchant. The attack requires only a normal user session and a proxy tool; no special privileges are needed. The vulnerability affects the core revenue process of the application. In a real e-commerce setting the cumulative loss could be substantial and would also damage customer trust and regulatory standing.

8.8 Remediation

8. Never accept price, discount or quantity values from the client for final order calculation.
9. Re-calculate the order total on the server using the authoritative product catalogue.
10. If a price must travel client-side for display, protect it with a server-generated HMAC or signed token.
11. Implement server-side authorization and integrity checks before committing any transaction.
12. Log and alert on anomalous price deviations relative to catalogue prices.
13. Add automated regression tests that attempt client-side price manipulation.

8.9 References

- OWASP Testing Guide — Business Logic Testing
- OWASP Top 10 — A04:2021 Insecure Design / A08:2021 Software and Data Integrity Failures
- PortSwigger Web Security Academy — Business logic vulnerabilities

9. Remediation Summary

Priority: HIGH — Calculate all prices server-side; discard client-supplied price parameters; add integrity checks and monitoring for anomalous transactions.

10. Conclusion

The validated finding JL-WEB-001 demonstrates a classic failure to enforce business rules on the server. By treating a client-controlled price as authoritative, the application allows trivial financial fraud. The issue was identified through disciplined manual testing: establishing a baseline, forming a clear hypothesis, modifying one variable at a time, and recording reproducible evidence. Remediation is straightforward and should be implemented before any production deployment of similar functionality. This report converts the Day 39 training observation into a complete, professional vulnerability record suitable for stakeholder communication.

11. Appendix

A. Evidence files: Burp Repeater screenshots (session tokens redacted) — retained by author.

B. Tooling: Burp Suite Professional (Proxy + Repeater).

C. Tester: Jiwosh Shrestha | Course: Web Security & Penetration Testing | Day 40.

D. All testing performed on authorized PortSwigger Academy lab instances only.